# Bezpieczeństwo informacji w umowach z dostawcami

Materiał edukacyjny do demonstracji. Ogólne zagadnienia bezpieczeństwa informacji.

### Zakres materiału

Uogólnione opracowanie edukacyjne zagadnień do rozważenia przy ocenie dostawcy. Nie jest tekstem normy ISO/IEC 27001, firmową procedurą ani deklaracją stosowanych zabezpieczeń.

### Zakres danych i dozwolone użycie

Należy określić informacje przekazywane dostawcy, sposób uzyskania do nich dostępu, ich wrażliwość oraz dozwolone i niedozwolone sposoby wykorzystania. Wymagania powinny uwzględniać zobowiązania wobec właścicieli informacji.

### Prawa i zobowiązania

Umowa powinna wyjaśniać obowiązki stron dotyczące ochrony danych, poufności, praw własności intelektualnej i praw autorskich. Wymagania należy dobrać do usługi i przetwarzanych informacji.

### Dostęp personelu

Należy określić zasady nadawania i cofania uprawnień personelu dostawcy. Dostęp powinien odpowiadać potrzebie wykonywania uzgodnionych zadań.

### Podwykonawcy

Należy ustalić warunki korzystania z podwykonawców, wymagania dotyczące ich zabezpieczeń oraz sposób informowania o zmianach. Obowiązki ochrony informacji powinny obejmować odpowiedni łańcuch dostaw.

### Incydenty i nadzór

W umowie warto określić sposób zgłaszania incydentów i współpracy przy usuwaniu ich skutków, dowody skuteczności zabezpieczeń, zakres audytu oraz sposób realizacji działań naprawczych.

### Zmiany usługi

Ocena powinna obejmować wcześniejsze informowanie o istotnych zmianach usługi, lokalizacji przetwarzania, zabezpieczeń lub podwykonawców oraz uzgodniony sposób reagowania na takie zmiany.

### Zakończenie współpracy

Należy ustalić zwrot lub usunięcie informacji, postępowanie z kopiami, dalsze obowiązywanie poufności oraz wsparcie przy przenoszeniu usługi. Retencję należy oceniać wraz z wymaganiami prawnymi i umownymi.